Implement and Manage Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

Implement and Manage Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

List of Team members:

S.No	Name	College Name	Contact
1	Neha S	Sri Ramakrishna college of arts and science for women	srcw23218b28@srcw.ac.in
2	Veenadevi N	Sri Ramakrishna college of arts and science for women	srcw23218b47@srcw.ac.in
3	Roshini S	Sri Ramakrishna college of arts and science for women	srcw23218b37@srcw.ac.in
4	Dharani T	Sri Ramakrishna college of arts and science for women	srcw23218b14@srcw.ac.in

Project details

Title: Implement and Manage Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

- **AI-Enhanced User Protection (AIUP)**

AI-Enhanced User Protection (AIUP) is a next-generation security framework that leverages artificial intelligence and machine learning to verify user identities and protect online platforms from cyber threats. Unlike traditional security measures that rely on static credentials like passwords or even two-factor authentication (2FA), AIUP continuously analyzes user behavior to create a dynamic, evolving "trust score" for each individual.

AIUP is essential for modern online security because it addresses the limitations of perimeter-based defenses. As cyber threats become more sophisticated—with attackers using stolen credentials, phishing, and social engineering—relying solely on "what you know" (passwords) or "what you have" (tokens) is no longer sufficient. AIUP adds a third, continuous layer: "who you are" based on how you behave. This system helps organizations prevent account takeovers, reduce fraud, and ensure that the person interacting with a platform is genuinely who they claim to be, throughout their entire session.

Abstract:

Legacy VPN models fall short in countering today's advanced security challenges, particularly in preventing lateral movement and avoiding excessive network privileges. This project presents the end-to-end design, deployment, and management of a Zero Trust Network Access (ZTNA) framework using Zscaler Private Access (ZPA) within a large institutional environment. Instead of providing broad network-level access, the solution enables application-specific, identity-based connectivity. Zscaler App Connectors are deployed within the data center and integrated with existing identity providers such as Azure AD and endpoint security tools, ensuring that all user-to-application sessions are securely brokered through a cloud-native intermediary. As a result, internal applications remain hidden from the public internet, eliminating direct exposure. The project also explores how Zscaler integrates with broader security ecosystems, including SIEM platforms like QRadar for centralized logging and MISP for threat intelligence integration, allowing the creation of adaptive access policies. Overall, the solution provides a scalable and resilient security architecture that enforces least-privilege access, ensures full visibility and auditability, and significantly enhances the organization's security posture.

Use Case Scenarios:

Scenario 1: Secure Remote Access for Faculty to ERP System

A faculty member working off-campus needs to log into the university's ERP platform to upload student grades. With Zscaler Private Access (ZPA), they establish a protected connection without being placed inside the internal network. Their identity is confirmed through Azure AD multi-factor authentication, and the device's security posture is checked before access is granted.

Output:

- Faculty identity validated through **Faculty_Group** authentication.
- Device compliance verified, ensuring **antivirus is active and the operating system is updated**.
- A **secure micro-tunnel** is established exclusively for access to the **ERP application**.
- The **internal network remains hidden and inaccessible** to the user, enhancing security.

Scenario 2: External Researcher Accessing a Specific Database

A visiting researcher from another institution requires temporary access to a specific research database hosted on the organization's servers. To ensure secure access, the administrator creates a temporary application-specific policy using the Zscaler platform. This policy allows the researcher to access only the designated research database while restricting visibility to other internal systems and resources.

Output:

- External identity verified using temporary credentials.
- Access policy applied with 7-day validity, restricted to Research-DB.
- The database remains hidden from public internet scans.
- User session automatically terminates when the policy expires.

Scenario 3: Student Access to Online Examination Portal

During final examinations, thousands of students access the internal online examination portal from various locations at the same time. To maintain security and performance, Zscaler ZPA ensures that only authenticated students using secure and compliant devices are allowed to connect to the exam server.

Output:

- Large-scale authentication handled efficiently through cloud scalability.
- Each student connected only to the examination application.
- DDoS attempts on the login page are mitigated**.**

Scenario 4: IT Administrator Performing Server Maintenance

An IT administrator needs to perform important maintenance tasks on an internal application server. Instead of using a traditional VPN that provides full network access, the administrator uses Zscaler ZPA to connect directly to the server's management interface.

Output:

- Administrator identity verified using Multi-Factor Authentication (MFA**)**.
- Secure micro-tunnel established only to the Server-Management Interface.
- All commands and keystrokes logged for auditing and monitoring.

Scenario 5: Mergers and Acquisitions – Temporary Contractor Access

During a university system upgrade, a contractor requires temporary access to a specific file server to perform data migration tasks. Instead of granting full network access through a traditional VPN, Zscaler ZPA provides secure, application-specific access to the contractor.

Output:

- Contractor identity verified through external Identity Provider (IdP) integration.
- Access restricted only to the File-Server-Migration share.
- All file transfer activities logged in Zscaler and the SIEM system.

Stage-1

Title Of the Project: - Implement and Manage Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

Overview: -

The project focuses on developing an **AI-powered identity verification system** that enhances online security by analyzing and validating user identities through their online behavior patterns. By using advanced machine learning techniques, the system creates strong behavioral profiles that help distinguish legitimate users from suspicious activities. This approach helps address security challenges such as unauthorized access, fraudulent transactions, and cyberattacks across various online platforms and services.

The main objective of the system is to improve online safety by continuously monitoring and verifying user identities through behavioral analysis. Technologies such as **deep learning, neural networks, and natural language processing** are used to create detailed behavioral models for each user. These models adapt and evolve over time based on changes in user activity. A key feature of the system is **real-time anomaly detection**.

To further strengthen security, the system activates **multi-factor authentication (MFA)** whenever abnormal behavior is maintain transparency and allow quick action if suspicious activity occurs. Sensitive data, including user profiles and anomaly information, is protected through **secure storage methods**, including encryption, strict access control, and compliance with privacy and data protection regulations.

The system also includes an **integration framework** that allows it to work seamlessly with different online platforms and services. Built-in monitoring and reporting tools provide visibility into system performance and security operations. The architecture is designed with **scalability and load balancing** to support a growing number of users. Additional security measures such as encryption of data in transit and at rest, firewalls, intrusion detection systems, and compliance with regulatory standards are implemented. The system can also be deployed in a **cloud environment**, providing flexibility, scalability, and efficient resource management.

Cloud deployment is available as an optional model, offering flexibility and scalability. Continuous retraining and optimization of machine learning models keep the system effective against evolving threats and changing user behaviors. Geographic distribution further enhances redundancy and performance by deploying components across multiple regions, ensuring resilience and faster response times.

Cloud deployment is offered as an optional model, giving flexibility and scalability to institutions that adopt it. Continuous retraining and optimization of machine learning models ensure the solution remains effective against evolving threats and changing user behaviors. Multi-factor authentication is incorporated to strengthen security, activating extra verification steps whenever irregularities are detected.

Geographic distribution further enhances resilience and performance by deploying components across multiple regions. This approach improves redundancy, reduces latency, and ensures faster response times for users regardless of location.

List of Vulnerability Table:

S.no	Vulnerability Name	CWE-no
1	Insertion of Sensitive Information Into Sent Data	CWE-201
2	External Control of System or Configuration Setting	CWE-15
3	Unimplemented or Unsupported Feature in UI	CWE-447
4	Weak Encoding for Password	CWE-261
5	Improper Input Validation	CWE-20
6	External Control of File Name or Path	CWE-73
7	Empty Password in Configuration File	CWE-258
8	Insufficient Verification of Data Authenticity	CWE-345

9	Improper Output Neutralization for Logs	CWE-117
10	Generation of Error Message Containing Sensitive Information	CWE-209

REPORT:-

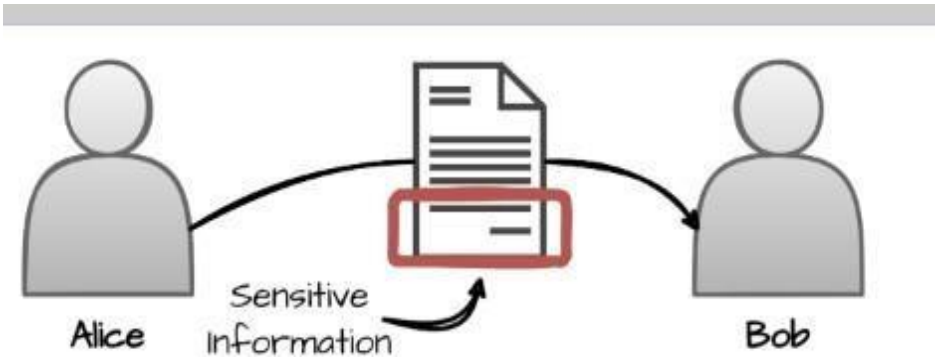
1)Vulnerability Name: Insertion of Sensitive Information Into Sent Data

CWE-201: Exposure of Sensitive Information through Sent Data

OWASP Category: A01:2025 Broken Access Control

Description: The code transmits data to another actor, but a portion of the data includes sensitive information that should not be accessible to that actor.

Business Impact: Exposure of sensitive information in transmitted data can lead to data breaches, unauthorized access, and misuse of confidential information by attackers or unintended recipients. This may result in financial losses, regulatory penalties, and damage to the organization's reputation and customer trust.



Recommendation:

1. **Apply Proper Access Control:** Ensure that sensitive information is only sent to authorized users or systems. Implement strict access control mechanisms to prevent unauthorized actors from receiving confidential data.
2. **Data Minimization:** Only transmit the minimum amount of data required for the intended functionality. Avoid including sensitive fields such as passwords, authentication tokens, personal data, or internal system information in responses or messages.

3. **Secure Data Transmission:** Use secure communication protocols such as HTTPS with TLS encryption to protect data while it is being transmitted between systems.
4. **Input and Output Validation:** Review application code to ensure that sensitive information is not accidentally included in API responses, logs, error messages, or third-party communications.
5. **Regular Security Reviews:** Conduct periodic code reviews, security testing, and vulnerability assessments to identify and prevent exposure of sensitive information in transmitted data.

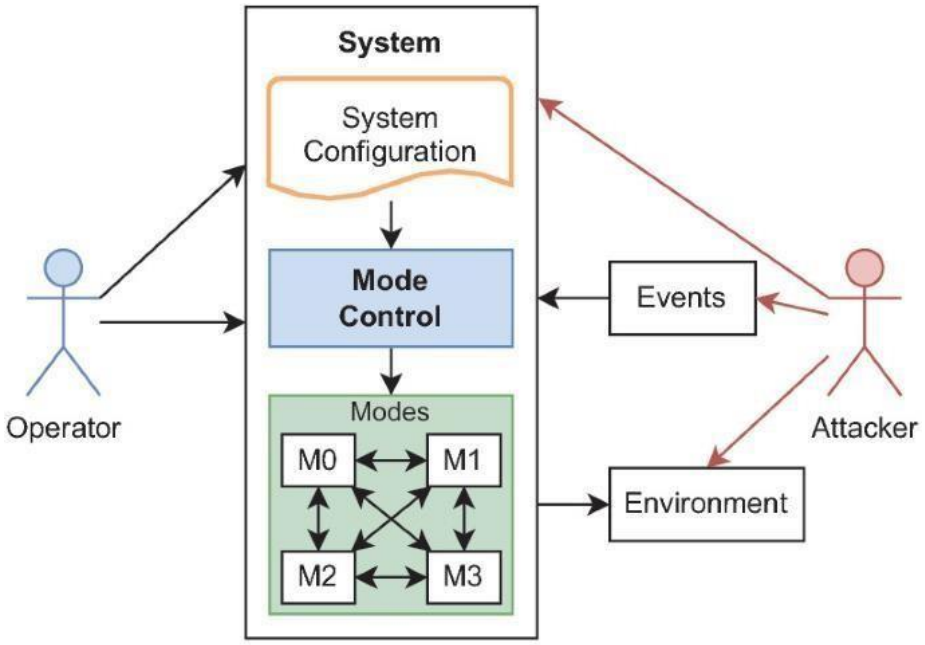
2) Vulnerability Name: External Control of System or Configuration Setting

CWE- 15 : External Control of System or Configuration Setting

OWASP Category: A02:2025 Security Misconfiguration

Description: One or more system settings or configuration elements can be externally controlled by a user.

Business Impact: External control of system or configuration settings can allow attackers to modify application behavior or system parameters, potentially leading to unauthorized access, system compromise, or service disruption. This can result in data exposure, operational downtime, financial losses, and damage to the organization's reputation and customer trust.



Recommendation:

1. **Restrict Configuration Access**: Ensure that system and configuration settings cannot be modified directly by external users. Only authorized administrators or trusted services should have permission to change configuration parameters.
2. **Input Validation**: Validate and sanitize all external inputs that may influence system configuration to prevent unauthorized manipulation of system settings.
3. **Use Secure Configuration Management**: Store configuration settings securely and avoid exposing them through user-controlled parameters such as URL requests, form inputs, or API calls.
4. **Implement Proper Access Controls:** Apply strong authentication and role-based access control to ensure that only privileged users can modify configuration settings.
5. **Regular Security Reviews**: Perform regular configuration audits and security assessments to detect misconfigurations and ensure that system settings are properly protected from external control.

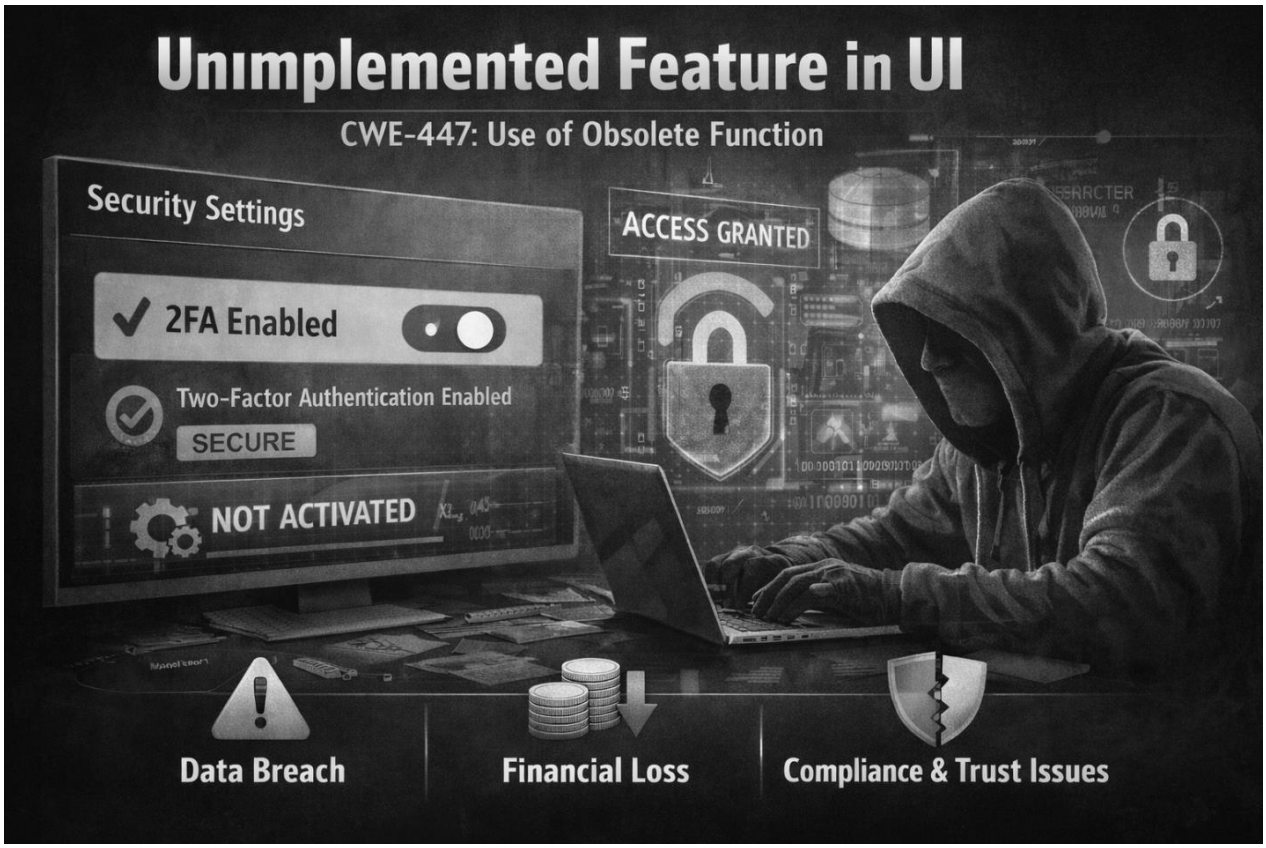
3) Vulnerability Name :- Unimplemented or Unsupported Feature in UI

CWE- 447 :- Use of Obsolete Function

OWASP Category: A03:2025 Software Supply Chain Failures

Description : - A UI function for a security feature appears to be supported and gives feedback to the user that suggests that it is supported, but the underlying functionality is not implemented.

Business Impact: - This vulnerability can create a false sense of security for users and administrators because the UI indicates that a security feature is available even though the actual functionality is not implemented. Attackers may exploit this weakness to gain unauthorized access to the system or sensitive data



Recommendation:

1. **Implement Backend Functionality for UI Features:** Ensure that every security feature displayed in the user interface is properly implemented and supported by the backend logic.
2. **Remove or Disable Unimplemented Features:** Do not display security options in the UI if the underlying functionality is not available or fully developed.
3. **Perform Regular Code Reviews and Security Testing:** Conduct periodic code reviews and vulnerability assessments to verify that UI actions correctly trigger the intended backend processes.
4. **Maintain Proper Documentation and Updates:** Clearly document implemented features and regularly update software components to avoid using obsolete or unsupported functions.

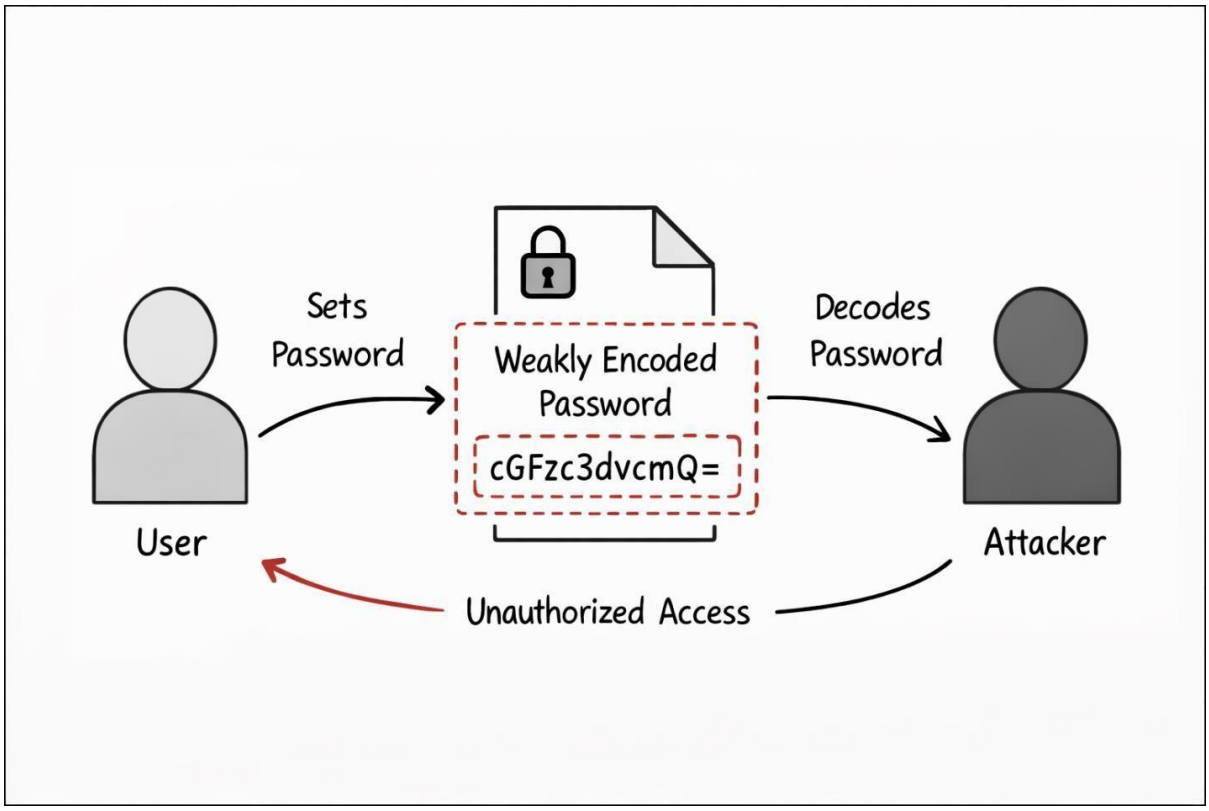
4) **Vulnerability Name**: - Weak Encoding for Password

CWE-261 :- Weak Encoding for Password

OWASP Category: A04:2025 Cryptographic Failures

Description :- Obscuring a password with a trivial encoding does not protect the password. give me the business impact of the above vulnerability

Business Impact :- Weak encoding of passwords does not provide proper protection, making it easier for attackers to decode and obtain user credentials. If passwords are exposed, attackers can gain unauthorized access to user accounts and sensitive systems. This can lead to data breaches, financial losses, and damage to the organization's reputation and customer trust.



Recommendation:

1. **Use Strong Password Hashing Algorithms:** Store passwords using secure hashing algorithms such as **bcrypt, Argon2, or PBKDF2** instead of simple encoding methods like Base64.
2. **Apply Salt to Passwords:** Add a unique random **salt value** to each password before hashing to prevent attackers from using precomputed attacks such as rainbow tables.
3. **Implement Secure Cryptographic Practices:** Follow secure cryptographic standards and avoid using weak or reversible encoding methods for protecting passwords.
4. **Regular Security Testing and Updates:** Conduct periodic security reviews and update cryptographic libraries to ensure strong protection against password exposure.

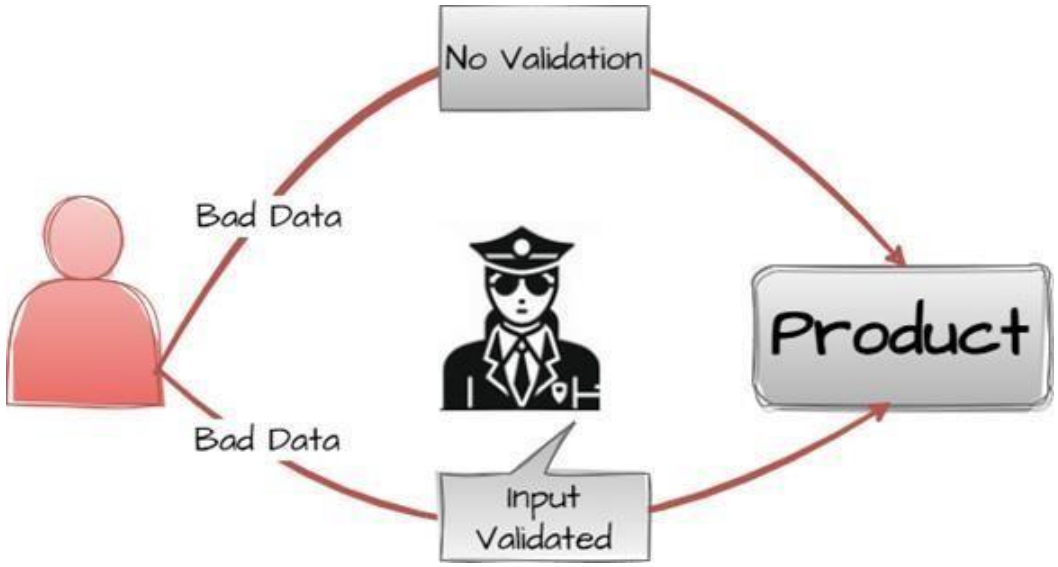
5) Vulnerability Name:- Improper Input Validation

CWE - 20 :- Improper Input Validation

OWASP Category:- A05:2025 Injection

Descripton :- The product receives input or data, but it does not validate or incorrectly validates that the input has the properties that are required to process the data safely and correctly.

Business Impact:- Improper input validation can allow attackers to submit malicious data into the system, which may lead to injection attacks such as SQL Injection or command execution. This can result in unauthorized access to sensitive data, system manipulation, or service disruption. As a result, the organization may face data breaches, financial losses, operational downtime, and damage to its reputation.



Recommendation:

1. **Implement Proper Input Validation:** Validate all user inputs on both client-side and server-side to ensure only expected and safe data is accepted.
2. **Use Parameterized Queries:** Use prepared statements or parameterized queries to prevent injection attacks such as SQL Injection.
3. **Apply Input Sanitization:** Sanitize and filter user inputs by removing or escaping malicious characters before processing them in the application.
4. **Use Security Frameworks and Regular Testing:** Utilize secure coding frameworks and perform regular security testing to identify and fix input validation issues.

6) Vulnerability Name: External Control of File Name or Path

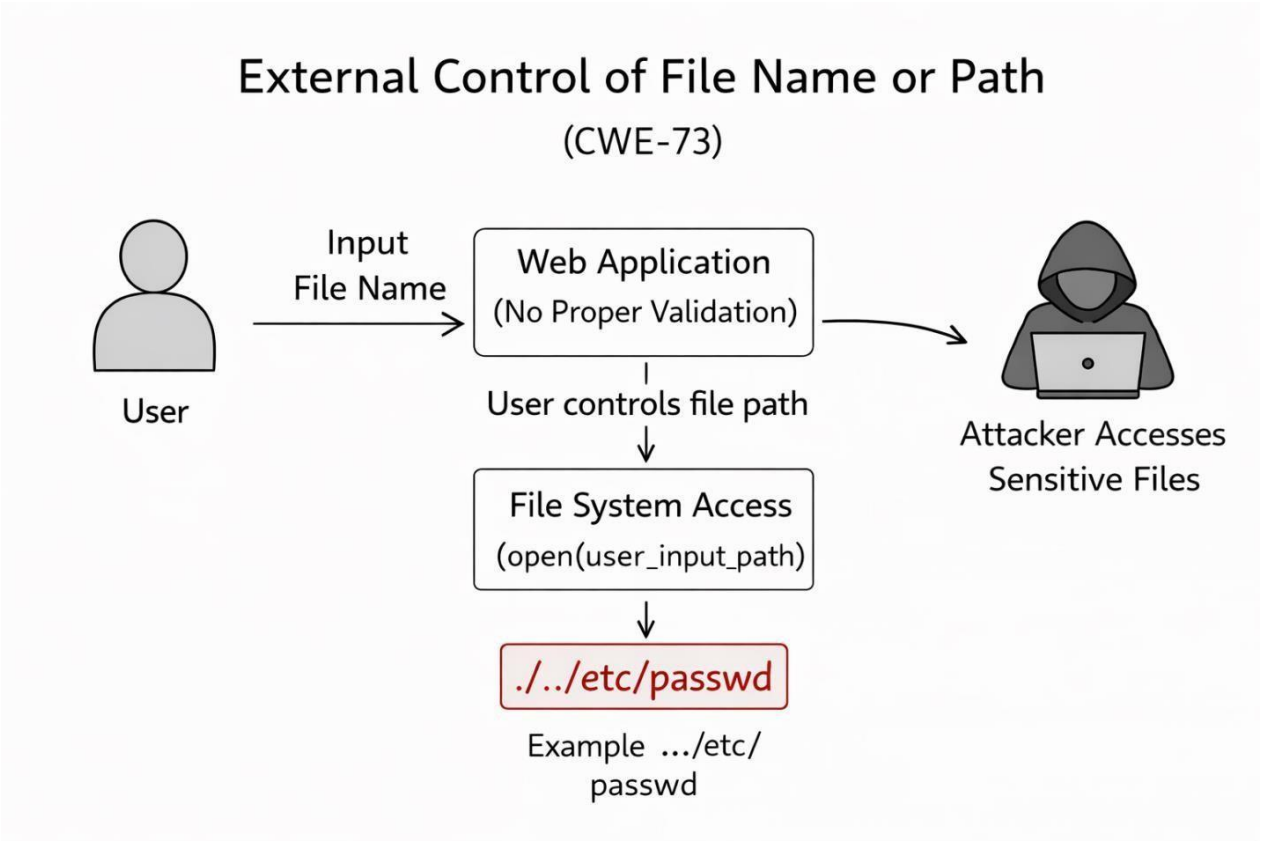
CWE-73:- External Control of File Name or Path

OWASP Category: A06:2025 Insecure Design

Description: The product allows user input to control or influence paths or file names that are used in filesystem operations.

Business Impact :- Allowing user input to control file names or file paths can enable attackers to access, modify, or delete sensitive files within the system. This may lead to unauthorized data

exposure, system compromise, or disruption of application services. As a result, the organization may suffer from data breaches, financial losses, operational downtime, and damage to its reputation.



Recommendation:

1. **Validate and Sanitize User Input:** Ensure that all file names and paths provided by users are properly validated and sanitized before being used in filesystem operations.
2. **Use Whitelisting for File Access:** Allow only predefined and permitted file names or directories instead of accepting arbitrary user input.
3. **Restrict File System Permissions:** Configure proper access controls and permissions to limit the application's ability to access sensitive system files.
4. **Implement Secure File Path Handling:** Use secure APIs and avoid directly concatenating user input into file paths to prevent path traversal attacks.

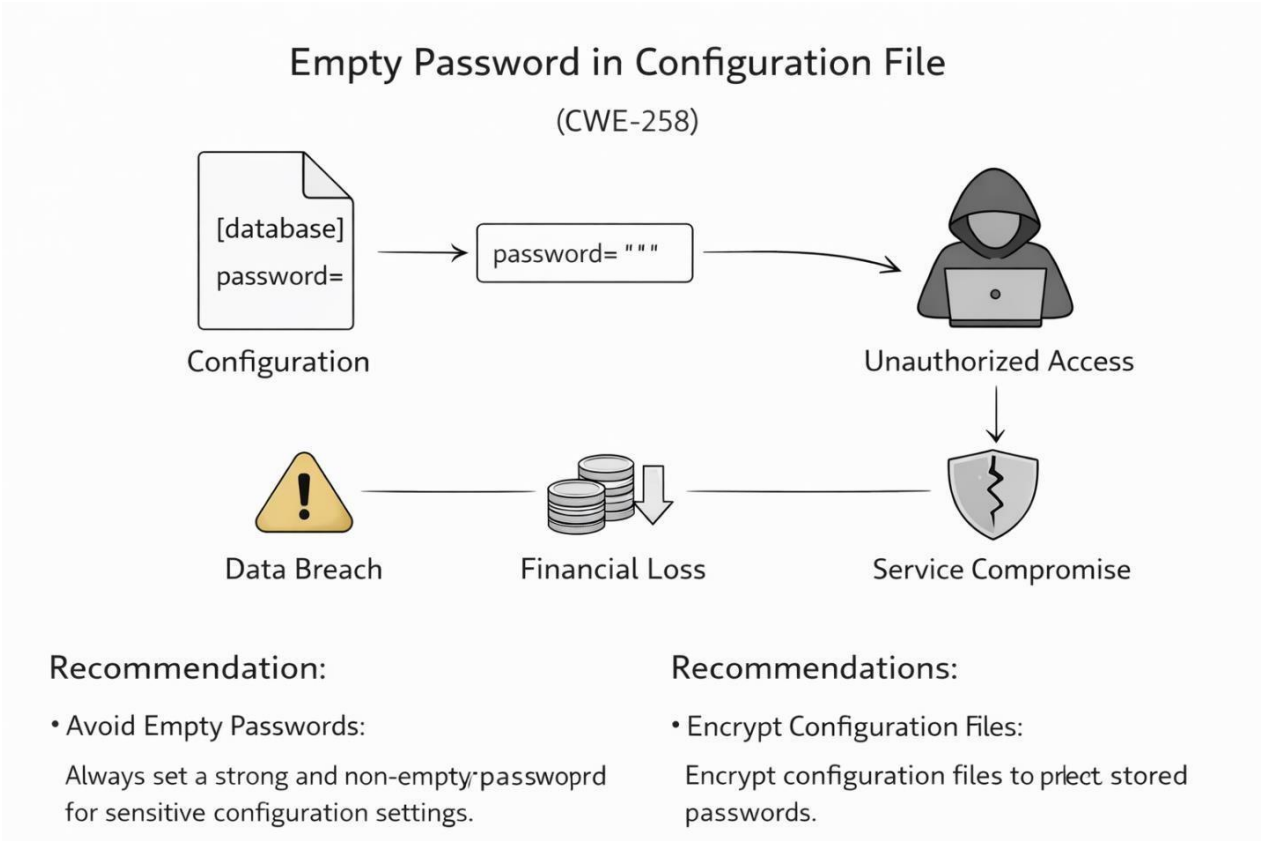
7) **Vulnerability Name :-** Empty Password in Configuration File

CWE-258:- Empty Password in Configuration File

OWASP Category: A07:2025 Authentication Failures

Description: Using an empty string as a password is insecure.

Business Impact:- Using an empty password in a configuration file can allow attackers to access systems, databases, or services without authentication. This can lead to unauthorized access to sensitive information and system resources. As a result, the organization may experience data breaches, service disruption, financial losses, and damage to its reputation.



Recommendation

1. **Avoid Empty Passwords:** Always configure strong and non-empty passwords for all configuration files and system components.

2. **Secure Configuration Files:** Restrict access permissions to configuration files so that only authorized users or services can read them.
3. **Use Encryption for Sensitive Data:** Store credentials in encrypted form or use secure secrets management systems instead of plain text.
4. **Regular Security Audits:** Periodically review configuration files and system settings to ensure that no empty or weak passwords are used.

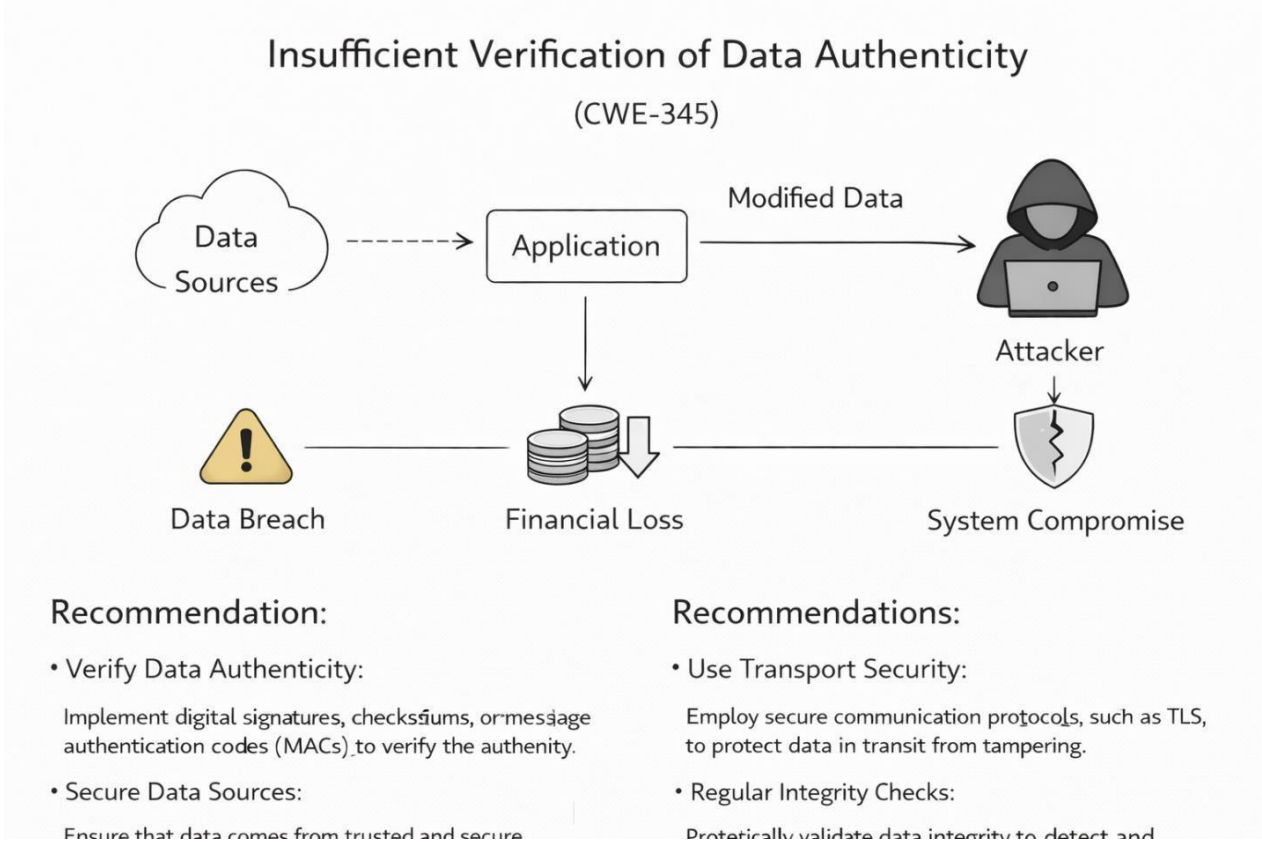
8) Vulnerability Name :- Insufficient Verification of Data Authenticity

CWE-345:- Insufficient Verification of Data Authenticity

OWASP Category: A08:2025 Software or Data Integrity Failures

Description: The product does not sufficiently verify the origin or authenticity of data, in a way that causes it to accept invalid data.

Business Impact:- Insufficient verification of data authenticity can allow attackers to modify or inject malicious data into the system. This may lead to unauthorized changes in application data, incorrect system operations, or distribution of compromised software. As a result, organizations may face data breaches, financial losses, operational disruptions, and loss of customer trust.



Recommendation

1. **Verify Data Authenticity:** Implement mechanisms such as digital signatures, message authentication codes (MAC), or checksums to ensure that data comes from trusted sources and has not been modified.
2. **Use Secure Communication Protocols:** Protect data in transit using secure protocols like TLS to prevent tampering or interception.
3. **Validate Data Sources:** Accept data only from trusted and verified sources to reduce the risk of malicious data injection.
4. **Perform Regular Integrity Checks:** Continuously monitor and verify the integrity of important files and data to detect unauthorized modifications.

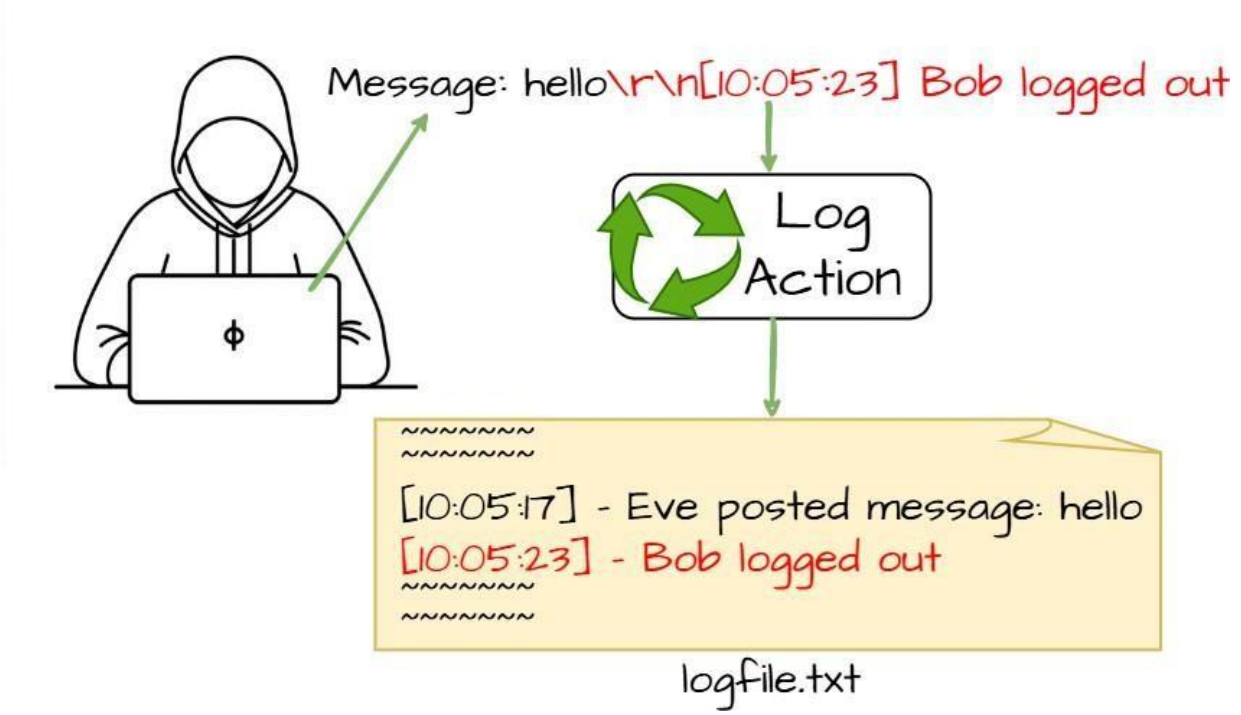
9) Vulnerability Name :- Improper Output Neutralization for Logs

CWE-117:- Improper Output Neutralization for Logs

OWASP Category: A09:2025 Security Logging & Alerting Failures

Description :- The product constructs a log message from external input, but it does not neutralize or incorrectly neutralizes special elements when the message is written to a log file.

Business Impact:- Improper output neutralization in logs can allow attackers to inject malicious or misleading log entries. This can manipulate log records, hide malicious activities, or create false information that misleads security monitoring systems. As a result, organizations may fail to detect security incidents in time, leading to data breaches, system compromise, and damage to business operations and reputation.



Recommendation

1. **Sanitize Log Inputs:** Ensure that all external inputs written to log files are properly sanitized to remove or escape special characters.
2. **Use Secure Logging Frameworks:** Implement trusted logging libraries that automatically handle input validation and output encoding.
3. **Restrict Log File Access:** Limit access to log files to authorized personnel to prevent unauthorized modification or viewing.

4. **Implement Log Monitoring and Alerts:** Continuously monitor logs and configure alerts to detect suspicious or unusual log activities.

10) Vulnerability Name :- Generation of Error Message Containing Sensitive Information

CWE-209:- Generation of Error Message Containing Sensitive Information

OWASP Category: A10:2025 Mishandling of Exceptional Conditions

Description :- The product generates an error message that includes sensitive information about its environment, users, or associated data.

Business Impact :- If error messages reveal sensitive information, attackers can gather details about the system such as database structure, file paths, configuration settings, or user data. This information can help attackers plan further attacks and exploit other vulnerabilities. As a result, the organization may face data breaches, system compromise, financial losses, and damage to its reputation.

Recommendation

1. **Limit Information in Error Messages:** Display only generic error messages to users and avoid exposing sensitive system details.
2. **Use Secure Error Handling Mechanisms:** Implement proper exception handling to prevent internal system information from being shown in error responses.
3. **Log Detailed Errors Securely:** Store detailed error information only in secure server logs for administrators instead of displaying it to users.
4. **Regular Security Testing:** Conduct regular security assessments to identify and fix information disclosure issues in application error handling.

STAGE 2

Overview :-

Nessus is a vulnerability scanning tool developed by Tenable, Inc.. It is a remote scanner, which means it does not need to be installed on the system being scanned. Instead, Nessus checks systems by sending different types of probes to identify security weaknesses. These probes may include network packets, operating system commands, and application requests.

Nessus operates using a plugin-based architecture. Plugins are small programs created to detect particular types of vulnerabilities. There are more than 1200 plugins available, covering vulnerabilities found in operating systems, software applications, and network devices.

During a scan, Nessus first performs host discovery to determine the operating system and the services running on the target machine. After identifying the host, it runs multiple plugins to check for possible vulnerabilities. When a vulnerability is detected, Nessus generates a detailed report that includes the severity level, how the vulnerability can be reproduced, and the recommended steps to fix the issue.

Nessus can scan different types of targets such as individual computers, entire networks, and web applications. It also allows scanning of specific ports and services. Users can configure Nessus to perform scans either manually or automatically at scheduled times.

Below is a simplified explanation of how Nessus operates step by step:

1. Nessus first establishes a connection with the target system using different network protocols such as TCP, UDP, and ICMP.
2. It then sends several probes to the target to determine the operating system and the services that are currently running.
3. After identifying the system details, Nessus executes multiple plugins designed to detect potential security vulnerabilities.
4. Once the scanning process is completed, Nessus produces a detailed report that shows the severity level of each vulnerability, instructions to reproduce the issue, and recommended solutions to fix it.

Nessus, developed by Tenable, Inc., is a useful tool for cybersecurity professionals because it helps them find and fix security weaknesses in their systems and networks. It is user-friendly and provides detailed reports that help organizations decide which vulnerabilities should be fixed first.

Here are some advantages of using Nessus:

● **Wide vulnerability detection:** Nessus includes more than 1200 plugins that help detect many types of vulnerabilities in operating systems, applications, and network devices.

● **User-friendly interface:** Nessus is designed with an easy-to-use interface, allowing users to quickly set up and perform vulnerability scans.

● **Detailed reporting:** After scanning, Nessus generates comprehensive reports that show the severity level of each vulnerability, how the issue can be reproduced, and the recommended steps to fix it.

● **Scalable scanning:** Nessus can scan different types of targets such as individual systems, complete networks, and web applications.

● **Flexible operation:** Users can run scans manually whenever needed or schedule them to run automatically at specific times.

Overall, Nessus, developed by Tenable, Inc., is a powerful vulnerability scanning tool that helps strengthen network security and is highly useful for security professionals.

Target website:- http://testfire.net/

Target ip address:- 65.61.137.117

List of vulnerability:-

s.no	**Vulnerability name**	**Severity**	**plugins**
1	TLS Version 1.0 Protocol Detection	MEDIUM	104743
2	TLS Version 1.1 Protocol Depricated	MEDIUM	157288
3	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	LOW	83875
4	ICMP Timestamp Request Remote Date Disclosure	INFO	10114
5	Additional DNS Hostnames	INFO	46180
6	Apache Tomcat Detection	INFO	39446

7	Common Platform Enumeration (CPE)	INFO	45590
8	Device Type	INFO	54615
9	HSTS Missing From HTTPS Server	INFO	84502
10	HTTP Server Type and Version	INFO	10107

REPORT: -

1) **Vulnerability Name: -** 104743 - TLS Version 1.0 Protocol Detection

Severity: - MEDIUM

Plugin: - 104743

Port: - 443

Description: - The remote service allows connections that are encrypted using TLS 1.0. However, TLS 1.0 contains several weaknesses in its cryptographic design. Although some modern implementations try to reduce these issues, newer versions such as TLS 1.2 and TLS 1.3 are more secure and are recommended for use.

Starting from March 31, 2020, systems that do not support TLS 1.2 or higher may not work properly with most major web browsers and software vendors.

According to the Payment Card Industry Security Standards Council standard PCI DSS v3.2, TLS 1.0 had to be completely disabled by June 30, 2018. The only exception was for POS POI terminals and their related SSL/TLS termination points, provided they were confirmed to be safe from known security vulnerabilities.

Solution: - Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Business Impact:- Continuing to use TLS 1.0 encryption, which has known cryptographic weaknesses, increases the organization's exposure to security threats such as cyberattacks and data breaches. This issue also creates compliance problems with industry standards, particularly PCI DSS v3.2, which requires the complete removal of TLS 1.0.

Failure to meet these requirements can result in regulatory penalties and may reduce customer confidence in the organization. In addition, systems that do not support TLS 1.2 or newer versions may not work properly with major web browsers and vendors. This could affect business operations, cause potential loss of customers, and harm the organization's reputation. Therefore, it is important to resolve this vulnerability to reduce security risks and maintain a reliable and secure online environment.

2) **Vulnerability Name:** - 157288 - TLS Version 1.1 Protocol Deprecated

Severity: - MEDIUM

Plugin: - 157288

Port: - 443

Description: - The remote service allows connections that use TLS 1.1 for encryption. However, TLS 1.1 does not support many modern and recommended cipher suites. It cannot use advanced encryption methods such as authenticated encryption modes like GCM or ciphers that perform encryption before MAC computation.

Since March 31, 2020, systems that do not support TLS 1.2 or newer versions may not work correctly with major web browsers and leading technology vendors. Therefore, upgrading to more secure protocols like TLS 1.2 or TLS 1.3 is recommended to ensure better security and compatibility.

Solution: - Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.

Business Impact:- Continuing to use TLS 1.1, which does not support modern cipher suites and advanced encryption techniques, weakens the organization's security and increases the risk of cyberattacks and data breaches. In addition, systems that are not upgraded to support TLS 1.2 or newer versions may face compatibility problems with major web browsers and technology vendors.

These compatibility issues can negatively affect user experience and may result in lost business opportunities. Therefore, it is important to address this vulnerability quickly in order to reduce security risks, maintain smooth communication with browsers and vendors, and protect the organization's reputation and operational performance.

3) **Vulnerability Name: -** 83875 - SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)

Severity: - LOW

Plugin: - 83875

Port: - 443

Description: - The remote host supports SSL/TLS connections that use Diffie-Hellman key exchange with moduli of 1024 bits or smaller. Keys of this size are considered weak, and through cryptanalysis an attacker may be able to determine the shared secret within a relatively short time, depending on the available resources.

If this happens, the attacker could potentially decrypt the transmitted data or interfere with the communication, compromising the confidentiality and integrity of the connection established through protocols such as SSL/TLS and the Diffie-Hellman key exchange method.

Solution: - Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

Business Impact: - Allowing SSL/TLS connections that use weak Diffie-Hellman moduli creates security risks. An attacker with enough computing power and resources may be able to break the shared secret in a short period of time. This could result in the decryption of sensitive information or compromise the integrity of the communication.

Although the severity of this issue may be considered low, it can still increase the chances of data exposure and connection manipulation. Therefore, it is important to fix this vulnerability to ensure stronger data protection and maintain user confidence in systems using SSL/TLS and the Diffie-Hellman key exchange mechanism.

4) **Vulnerability Name: -** 10114 - ICMP Timestamp Request Remote Date Disclosure

Severity: - INFO

Plugin: - 10114

Port: - 0

Description: - The remote system responds to ICMP timestamp requests. Because of this, an attacker can determine the system time set on the target machine. This information may help an unauthenticated remote attacker bypass or weaken security mechanisms that rely on time-based authentication.

In systems running Windows Vista, Windows 7, Windows Server 2008, and Windows Server 2008 R2, the timestamps returned are intentionally inaccurate. However, they are usually still within about 1000 seconds of the actual system time.

Solution: - Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Business Impact:- -This does not pose an immediate threat to business operations or data security. This vulnerability allows external parties to request the system's date and time information remotely. While it does not present a significant risk, it could potentially be used by attackers for reconnaissance purposes. Therefore, it is advisable to address this vulnerability as part of a broader security posture to reduce the risk of unauthorized data gathering and protect against potential future threats.

5) **Vulnerability Name: -** 46180 - Additional DNS Hostnames

Severity: - INFO

Plugin: - 46180

Port: - 0

Description: - Various plugins have identified hostnames that are different from the current hostname. Nessus vulnerability scanner has created a list of these alternative hostnames that are associated with the same remote host.

These hostnames represent additional names through which the web server can be accessed. In many cases, multiple websites or services can run on the same server using name-based virtual hosting, where different hostnames are used to direct requests to different web applications on the same system.

Solution: - If you want to test them, re-scan using the special vhost syntax, such as :

www.example.com [192.0.32.10]

Business Impact: - This issue does not create an immediate risk to business operations or data security. It simply indicates that additional hostnames linked to the same remote host have been identified, which commonly occurs when web servers use name-based virtual hosting.

Although this information is not considered a direct security vulnerability, it can help in understanding the server configuration and overall network structure. Organizations can

include these discovered hostnames in their network documentation for reference. Since it does not pose a direct threat, no urgent action is required to address it according to results reported by tools such as Nessus vulnerability scanner.

6) Vulnerability Name: - 39446 - Apache Tomcat Detection

Severity: - INFO

Plugin: - 39446

Port: - 80

Description: -Nessus was able to detect a remote Apache Tomcat web server.

Solution: - n/a

Business Impact: - This is an informational result that indicates the presence of a remote Apache Tomcat web server. The finding itself does not represent a security vulnerability or pose a direct risk to business operations.

However, identifying the technologies running on a network can be helpful for system administrators and security teams. Knowing that an Apache Tomcat server is in use helps with proper management, maintenance, and security of web applications. Since it is only informational, no immediate action is required to address a security concern.

7) Vulnerability Name: - 45590 - Common Platform Enumeration (CPE)

Severity: - INFO

Plugin: - 45590

Port: - 0

Description: - Using details collected during a scan performed by the Nessus vulnerability scanner, this plugin identifies and reports CPE matches for different hardware and software products detected on the host.

Common Platform Enumeration (CPE) is a standardized naming system used to identify IT products. If an official CPE entry is not available for a particular product, the plugin generates the closest possible CPE value based on the information gathered during the scan.

Solution: - n/a

Business Impact: - This finding gives information about the hardware and software products detected on a host during a scan performed by the Nessus vulnerability scanner. It reports CPE matches, which are standardized identifiers used to describe these products.

This information is helpful for asset management and maintaining an accurate inventory of systems. Although it does not represent a security risk, it helps administrators better understand the technologies present in their network. This knowledge supports better resource management and makes future system maintenance and updates easier.

8) Vulnerability Name: - Device Type

Severity: - INFO

Plugin: - 54615

Port: - 0

Description: - Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Business Impact: - This information helps identify the type of remote device—such as a printer, router, or general-purpose computer—by analyzing its operating system. Although it does not represent a direct security risk, it provides useful details for network administrators to understand and categorize the devices connected to their network.

Having this information improves network management and optimization. It also helps administrators apply suitable security controls and configurations for each type of device discovered during scans performed by tools like Nessus vulnerability scanner.

9) Vulnerability Name: - 84502 - HSTS Missing From HTTPS Server

Severity: - INFO

Plugin: - 84502

Port: - 443

Description: - The remote HTTPS server does not enforce HTTP Strict Transport Security (HSTS). HSTS is a security header that can be configured on the server to ensure that browsers always connect to the website using HTTPS instead of HTTP.

When HSTS is not enabled, attackers may be able to perform downgrade attacks or SSL-stripping man-in-the-middle attacks, forcing the connection to use an insecure protocol. This also reduces protection against cookie hijacking and other security risks related to web communication using HTTP Strict Transport Security and HTTPS.

Solution: - Configure the remote web server to use HSTS.

Business Impact:- This finding shows that the remote HTTPS server does not enforce HTTP Strict Transport Security (HSTS). HSTS is an important security feature that tells web browsers to always communicate with the server using HTTPS, which helps improve the security of web connections.

When HSTS is not enabled, the server may become vulnerable to downgrade attacks and SSL-stripping man-in-the-middle attacks. It also reduces the protection against cookie hijacking, which can put sensitive user information at risk. Enabling HSTS is therefore important to strengthen security and ensure that data transmitted between users and the server remains protected.

10) Vulnerability Name: - 10107 - HTTP Server Type and Version

Severity: - INFO

Plugin: - 10107

Port: - 443

Description: - This plugin attempts to determine the type and the version of the remote web server.

Solution: - N/A

Business Impact: - -This relates to the identification of the remote web server's type and version. While this issue doesn't pose an immediate security threat, it can provide valuable information to potential attackers about the server's software stack. Knowledge of the server type and version may aid attackers in exploiting known vulnerabilities specific to that software, making it important to restrict such information from being easily accessible to enhance the server's overall security posture

STAGE-3

Report: -

Title: - Implementing Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

Zero Trust Network Access (ZTNA)

Zero Trust Network Access (ZTNA) is a modern cybersecurity framework that provides secure remote access to an organization's internal applications and resources. Unlike traditional security models that trust users once they enter the network, ZTNA follows the principle "Never Trust, Always Verify."

In traditional systems such as Virtual Private Networks (VPNs), users who successfully authenticate are often granted access to large parts of the internal network. This creates security risks because attackers who compromise a user account may move freely within the network.

ZTNA solves this issue by granting users access only to the specific applications they need, rather than giving access to the entire network. Each access request is verified based on user identity, device security posture, and predefined security policies.

This approach eliminates the traditional "castle-and-moat" security model, where the internal network is trusted and the external network is not. Instead, ZTNA hides internal resources from the internet and establishes secure, encrypted connections between authenticated users and applications. This significantly reduces the attack surface and prevents threats such as lateral movement.

ZTNA Access Cycle

The ZTNA access cycle is a continuous process that verifies identity, enforces policies, and monitors connections to ensure secure access.

1. User Request

A user from any location—such as an office, home, or public network—requests access to a specific internal application like an HR portal, finance server, or internal development repository.

2. Identity and Device Verification

Before granting access, the ZTNA system verifies the user's identity using Multi-Factor Authentication (MFA) and checks the security posture of the device. This includes verifying antivirus status, firewall configuration, and ensuring that the device is not compromised.

3. Policy Enforcement

The system evaluates predefined access policies to determine whether the user and device are authorized to access the requested application at that specific time.

4. Secure Connection Establishment

If the request satisfies the security policies, the ZTNA platform creates a secure and encrypted micro-tunnel between the user's device and the target application. Importantly, the user gains access only to the specific application and not to the underlying network.

5. Continuous Monitoring

During the session, the system continuously monitors user behavior and device health. If suspicious activity is detected or the device becomes non-compliant, the connection can be terminated immediately.

6. Logging and Analytics

All access attempts, both successful and unsuccessful, are recorded. This data helps organizations perform security audits, detect potential threats, and improve access control policies.

Zscaler and ZTNA

Zscaler is a cloud-native security platform that provides Zero Trust solutions without requiring traditional on-premises hardware like VPN gateways.

A key service offered by Zscaler is Zscaler Private Access (ZPA), which enables secure, identity-based access to private applications without placing users directly on the corporate network.

ZPA operates through the Zscaler cloud platform and integrates with several components:

1. Identity Providers

These systems verify user identities before access is granted. Examples include Microsoft Azure Active Directory, Okta, and Ping Identity.

2. Device Security Platforms

These tools assess the security posture of user devices. Examples include CrowdStrike Falcon, Tanium, and Microsoft Defender for Endpoint.

3. Business Applications

These are the internal applications hosted in private data centers or public cloud platforms such as Amazon Web Services and Microsoft Azure.

4. Zscaler App Connectors

These are lightweight software components installed in data centers or cloud environments. They create secure outbound connections to the Zscaler cloud, ensuring that internal applications remain hidden from the public internet.

Policy Enforcement in Zscaler

After collecting identity, device posture, and application data, Zscaler enforces security policies to control access to internal resources. These policies ensure that users are granted secure and controlled access based on Zero Trust principles.

1. Identity-Based Access

Access policies are defined based on user identities and group memberships rather than traditional network identifiers such as IP addresses. This allows organizations to control access more accurately by verifying who the user is and what role they have within the organization.

2. Application Segmentation

Instead of granting users access to entire networks or subnets, Zscaler provides application-level segmentation. Users are permitted to connect only to the specific applications required for their work. This prevents unauthorized access to other internal systems and significantly reduces the potential attack surface.

3. Least Privilege Access

The platform follows the principle of least privilege, which ensures that users are given only the minimum level of access necessary to perform their job responsibilities. By limiting permissions, organizations can reduce the risk of accidental misuse, insider threats, and damage caused by compromised accounts.

The Zscaler ZTNA Cycle

The Zero Trust Network Access (ZTNA) model implemented by Zscaler provides secure, identity-based access to private applications through its cloud platform. The Zscaler ZTNA cycle represents the practical workflow used to verify users, enforce policies, and establish secure connections between users and applications.

1. User Login and Authentication

When a user attempts to access an internal application, the request is redirected to the organization's Identity Provider (IdP) for authentication. The user must verify their identity, typically through Multi-Factor Authentication (MFA), ensuring that only authorized individuals can proceed.

2. Device Posture Verification

After authentication, the Zscaler platform checks the security status of the user's device by integrating with endpoint protection tools. This step ensures that the device complies with the organization's security policies, including updated antivirus software, active firewall protection, and secure operating system configuration.

3. Policy Evaluation and Access Decision

The Zscaler cloud platform evaluates the access request against predefined security policies. These policies verify whether the user, device, and contextual factors —such as time and location—are permitted to access the requested application.

4. Establishment of a Secure Micro-Tunnel

If the request is approved, the Zscaler platform creates an encrypted micro-tunnel between the user's device and the target application. This connection is established through the Zscaler Client Connector on the user's device and the Zscaler App Connector located in the data center

or cloud environment. The user gains access only to the authorized application, not the entire network.

5. Traffic Inspection (Optional)

Zscaler can optionally inspect the application traffic to detect malicious activity or prevent sensitive data leakage. This includes applying security controls such as malware detection and Data Loss Prevention (DLP) policies.

6. Logging and Analytics

All user activities and access attempts are recorded in the Zscaler cloud portal. These logs support security monitoring, threat investigation, compliance auditing, and policy optimization.

MISP Integration with Zscaler

Malware Information Sharing Platform (MISP) provides threat intelligence about malicious domains,IPaddresses,URLs.
When integrated with Zscaler Internet Access, this data allows the system to automatically block connections to known malicious websites and improve threat detection.

College Network Infrastructure

A typical college network contains routers, switches, wireless access points, firewalls, IDS, and internal servers that host student portals, research systems, and administrative applications. Many colleges still use legacy VPN systems for remote access.

Limitations of VPN

- Users receive broad network access
- Risk of lateral movement if devices are compromised
- External collaborators require limited application access
- VPN may create slow connectivity

Deploying ZTNA with Zscaler

Using Zscaler Private Access, colleges can provide secure access by allowing users to connect only to required applications instead of the entire network. This reduces security risks and improves remote access performance.

ZTNA Deployment Plan Using Zscaler

To implement Zero Trust access in a college network using Zscaler, the following steps can be followed:

1. Application Discovery
   Identify and document all internal applications such as ERP systems, library databases, research servers, and file storage services currently accessed through VPN.
2. User Segmentation
   Categorize users into groups such as students, faculty, IT staff, and external collaborators, and determine the applications required for each group.
3. Deploy App Connectors
   Install Zscaler App Connector in the university data center to create secure outbound connections to the Zscaler cloud and protect internal servers from public exposure.
4. Identity Provider Integration
   Integrate Zscaler with identity platforms like Microsoft Azure Active Directory to use existing authentication systems and multi-factor authentication.
5. Access Policy Configuration
   Define detailed security policies in the Zscaler portal to control which users can access specific applications under defined conditions.
6. Client Connector Deployment
   Install Zscaler Client Connector on user devices so that private application traffic is securely routed through Zscaler's Zero Trust platform.

Threat Intelligence in ZTNA

In a Zero Trust environment using Zscaler, threat intelligence helps evaluate access requests based on user behavior, location, and risk level, not just identity.

Sources of Threat Intelligence

1. Zscaler Cloud Logs – provide real-time information about user access activities, device details, and geographic locations.
2. External Threat Feeds – platforms such as Malware Information Sharing Platform (MISP) share data about malicious domains, IP addresses, and ongoing attack campaigns.
3. Identity Provider Logs – authentication systems like Microsoft Azure Active Directory detect abnormal login behavior that may indicate compromised accounts.

Uses of Threat Intelligence

1. Adaptive Access Control – high-risk access attempts may require stronger verification or be denied.
2. Detection of Compromised Accounts – unusual user behavior in logs can reveal potential credential theft.
3. Malicious Traffic Blocking – Zscaler Internet Access can prevent users from connecting to known malicious domains or servers.

Incident Response in a ZTNA Environment

In a Zero Trust architecture using Zscaler, incident response becomes faster and more precise because users are connected only to specific applications rather than the entire network.

Incident Response Process

1. Detection
   Security teams monitor Zscaler logs to identify suspicious activities such as unusual data transfers or abnormal login behavior.

2. Containment
   Access for the affected user or device can be instantly disabled through the Zscaler management portal, immediately blocking all application connections.
3. Eradication
   The compromised device is isolated and scanned by IT teams to remove malware or security threats.
4. Recovery
   Once the system is secure and credentials are reset, access policies are reactivated for the user.
5. Post-Incident Analysis
   Security teams review logs to determine the cause of the incident and update security policies to prevent similar attacks.

Key Benefits

- Rapid containment of threats through centralized cloud control
- No lateral movement, as attackers cannot access the full network
- Detailed forensic logs for faster investigations
- Improved regulatory compliance for sensitive data protection

Understanding the Zscaler ZPA Tool

Zscaler Private Access (ZPA) is a cloud-based security service from Zscaler that implements the Zero Trust principle of connecting users directly to applications rather than to the network.

Key Features

1. Application-Centric Access
   Security policies are created for specific applications instead of network addresses or subnets.

2. Network Invisibility
   Internal applications are protected using App Connectors, which create secure outbound connections to the Zscaler cloud without exposing servers to the internet.
3. Dark Cloud Architecture
   Applications remain hidden from external users and are visible only after successful authentication and authorization.
4. Improved User Experience
   The Zscaler Client Connector automatically handles secure connections, eliminating the need for traditional VPN clients.
5. Cloud-Based Scalability
   As a cloud service, ZPA can easily scale to support large numbers of users without additional on-premise infrastructure.

Conclusion:-

The exploration of AI-driven web security and Zero Trust architecture has provided valuable insights into modern cybersecurity practices.

Stage 1 focused on web application testing, highlighting the importance of identifying vulnerabilities and protecting web-based systems from potential cyber threats. This stage established the foundation for understanding secure application development and risk assessment.

Stage 2 examined vulnerability analysis through reports generated by Nessus. Studying these reports emphasized the importance of continuous monitoring and proactive identification of system weaknesses, enabling organizations to implement effective security measures.

Stage 3 introduced the concept of Zero Trust Network Access (ZTNA) and its implementation using Zscaler Private Access, a solution provided by Zscaler. This model represents a major shift from traditional VPN-based access to a secure, identity-based approach where users connect directly to applications rather than the entire network. By hiding internal applications, enforcing granular access policies, and preventing lateral movement, ZTNA significantly strengthens organizational security.

Final Insight

This project provided a comprehensive understanding of modern cybersecurity practices, particularly the implementation of Zero Trust security using Zscaler Private Access from Zscaler. It highlighted how organizations can strengthen their security posture by moving away from traditional network-based access models toward identity-driven and application-focused protection.

By exploring web application testing, vulnerability assessment, and Zero Trust architecture, the project demonstrated the importance of proactive security strategies in defending against continuously evolving cyber threats.

Future Scope

Future of Web Application Testing (WAT)

The future of Web Application Testing is promising as modern web applications continue to grow in complexity and importance for business operations. Ensuring their security, reliability, and usability will remain a critical priority for organizations.

Key trends expected to shape the future of WAT include:

1. Increased Focus on Security
With the rise of sophisticated cyberattacks, organizations will prioritize security testing to detect vulnerabilities and protect sensitive data.

2. Integration of Artificial Intelligence and Machine Learning
AI and ML technologies will automate repetitive testing tasks, generate intelligent test cases, and detect complex security patterns that traditional methods may overlook.

3. Growth of Cloud-Based Testing Platforms
As more applications migrate to cloud environments, cloud-based testing solutions will become more popular due to their scalability, flexibility, and cost efficiency.

4. Greater Emphasis on User Experience (UX) Testing
Future testing strategies will increasingly focus on ensuring that web applications provide seamless, intuitive, and user-friendly experiences.

Overall, advancements in AI, automation, and cloud technologies will continue to transform web application testing, enabling organizations to build more secure, efficient, and reliable digital systems.

Future Scope of the Testing Process

The future of the software testing process is highly promising as modern applications continue to grow in complexity and importance for business operations. Organizations increasingly depend on reliable software systems, making effective testing essential for maintaining quality, performance, and security.

Several key trends are expected to shape the future of software testing:

1. Continuous Testing

Continuous testing integrates testing activities throughout the entire Software Development Life Cycle (SDLC). This approach helps identify defects early in the development process and ensures faster and more reliable software delivery.

2. Integration of Artificial Intelligence and Machine Learning

AI and ML technologies are transforming the testing process by automating repetitive tasks such as test case generation and execution. These technologies can also identify hidden patterns, anomalies, and potential defects that traditional testing methods might miss.

3. Growth of Cloud-Based Testing

Cloud-based testing platforms provide scalability, flexibility, and cost efficiency. As more organizations adopt cloud technologies, testing environments will increasingly shift to cloud-based solutions.

4. Expansion of Test Automation

Automation tools enable the execution of test cases without manual intervention, reducing testing time and improving efficiency. Automated testing also supports continuous integration and rapid software deployment.

Overall, advancements in automation, AI-driven tools, and cloud technologies will significantly enhance the speed, accuracy, and effectiveness of the software testing process.

Future Scope of SOC / SIEM with Zero Trust Network Access (ZTNA)

The future scope of Zero Trust Network Access (ZTNA) and modern security frameworks is rapidly expanding due to the growth of cloud computing, remote work, and advanced cyber threats. Organizations are increasingly adopting Zero Trust principles to ensure stronger protection for their digital assets.

1. AI-Driven Zero Trust Security

Future Zero Trust systems will incorporate Artificial Intelligence (AI) and Machine Learning (ML) to analyze user behavior and detect unusual activities. These intelligent systems will continuously monitor network traffic and automatically adjust access permissions based on risk levels, creating a dynamic and adaptive security environment.

2. Integration with Edge Computing and IoT

As organizations deploy more Internet of Things (IoT) devices and edge computing systems, Zero Trust frameworks will extend security to these environments. Lightweight authentication mechanisms and secure communication protocols will help protect machine-to-machine communication and prevent large-scale cyberattacks such as botnets.

3. Identity-Centric Security Model

In the future, identity will become the primary security boundary. Advanced identity verification techniques such as behavioral biometrics, including keystroke patterns and movement analysis, will ensure continuous user authentication. Decentralized identity technologies using blockchain may also be used to provide secure and tamper-proof identity management.

4. Integration with Secure Access Service Edge (SASE)

Zero Trust will play a crucial role in SASE architecture, which combines multiple cloud-based security services such as secure web gateways, cloud access security brokers, and firewall-as-a-service. This integration will provide unified security management and consistent protection for users accessing resources from any location.

5. Protection of Operational Technology (OT)

Critical sectors such as energy, healthcare, and manufacturing will increasingly adopt Zero Trust models to secure Operational Technology (OT) systems. Specialized Zero Trust

solutions will be developed to protect industrial control systems and critical infrastructure from advanced cyber threats and nation-state attacks.

6. Automated Threat Detection and Response

Future Zero Trust environments will integrate with Security Orchestration, Automation, and Response (SOAR) tools to enable automated security operations. When suspicious activity is detected, the system can automatically isolate compromised devices, initiate investigation workflows, and mitigate threats without manual intervention.

Topics Explored

- Data Collection & Aggregation – Collecting logs and security data from multiple systems.
- Standardization & Normalization – Converting different log formats into a standard format.
- Enrichment & Analysis – Adding extra threat information to improve detection.
- Sharing & Distribution – Sharing threat intelligence with security systems.
- Integration with Security Tools – Connecting SIEM with other security tools.
- Customization & Flexibility – Adjusting security rules and alerts.
- Automation & Orchestration – Automating security responses.
- Community Involvement – Using shared cybersecurity knowledge.
- Incident Response Support – Helping detect and respond to attacks.
- Threat Intelligence Feeds – External sources providing information about new threats.

Tools Explored

- Nmap – Scans networks to find devices and services.
- Metasploit – Used for penetration testing and exploiting vulnerabilities.
- Nessus – Scans systems for security vulnerabilities.
- Kali Linux – Operating system with many ethical hacking tools.

- OWASP ZAP – Finds vulnerabilities in web applications.
- Burp Suite – Tests web application security.

THE END